Phishing Scenario and Lab

Laura Kraman

October 4, 2026

This report analyzes an attack that uses a phishing email impersonating the information technology (IT) department, a pretexting phone call, and a counterfeit login portal to steal an employee's credentials at a mid-sized company. The attack exploits trust in internal communication. The most effective defense is independent verification of identity and requests.

Description of the Scenario and Tactics Used

The attack combines reconnaissance, spear phishing, spoofing, and pretexting (TryHackMe, n.d.-a). The attacker may have studied the company's IT emails and support portal to create look-alike versions. The spoofed email impersonates IT and announces an urgent security update, using authority, urgency, and fear to prompt compliance.

The email prepares the employee for the follow-up call, where the attacker uses pretexting and voice phishing, posing as a support technician who needs the employee's password to complete the update. The email and call appear to confirm each other, although both come from the attacker. The email's link leads to a spoofed portal on a look-alike domain, a credential-harvesting technique (TryHackMe, n.d.-b, n.d.-e). The call and portal give the attacker two chances to capture the same credentials, which the attacker then uses to log in to the internal network and look for further vulnerabilities.

Evaluation of the Attack's Effectiveness and Potential Impact

The attack can be effective because employees routinely receive IT notices and support calls, and each channel makes the other seem legitimate. It remains plausible wherever accounts rely on passwords alone. An unfamiliar caller number might raise suspicion, but caller ID can be falsified (Federal Communications Commission [FCC], n.d.). Attackers also continue to impersonate IT help desk staff by phone and bypass multifactor authentication (MFA) through repeated push notifications (Cybersecurity and Infrastructure Security Agency [CISA], 2025).

Some employees are easier targets than others. The scenario does not state the employee's tenure, which may matter. Westholt and Straub (2025) found that each additional year of employment made employees about 7% less likely to click a phishing link and 8% less likely to enter credentials. New hires may face additional risk because setup requests are routine.

The attack can still fail if the employee notices an external-sender banner or mismatched domain, questions why IT needs a password, or verifies the call through the company directory.

The impact depends on the account's permissions and how quickly the intrusion is detected. Unauthorized access could expose customer records, employee information, or intellectual property, leading to fraud, recovery costs, and damaged customer trust. If the employee reuses the password, the attacker could also try it on other services through credential stuffing (TryHackMe, n.d.-a). Containment could disrupt operations as accounts are disabled or access to affected systems is restricted.

Suggestions for Improvements or Alternative Approaches

The attack would be harder to detect if the email and call matched the company's real language and support procedures (TryHackMe, n.d.-b). The attacker could have the employee enter the password on the cloned portal rather than say it aloud or include an attacker-controlled "verification" number in the email. Alternative approaches include SMS phishing, vendor impersonation, or a password-reset pretext aimed at the help desk.

Detection and Prevention Recommendations

Training should cover email and phone deception and begin during onboarding. Employees should check sender addresses and link destinations or go directly to the real site (TryHackMe, n.d.-a). New hires should practice hanging up on a simulated IT call and calling back through the directory, as CISA (2024) recommends for suspected impersonation calls. Policy should state that IT will never request a password or MFA code, since clearly defined processes help employees recognize fraudulent requests (National Cyber Security Centre [NCSC], n.d.). A phishing reporting button and a blameless reporting culture encourages fast reporting (NCSC, n.d.).

Technical controls should include email filtering, external-sender warnings, and deploy Sender Policy Framework and DomainKeys Identified Mail with an enforced Domain-based Message Authentication, Reporting, and Conformance policy. These limit spoofing of the company's own domain but not look-alike domains (TryHackMe, n.d.-f). Analysts should examine headers and link targets in reported messages (TryHackMe, n.d.-c, n.d.-d). The company should require phishing-resistant MFA, such as FIDO2 security keys or passkeys, which will not authenticate to a fake portal (CISA, n.d.; National Institute of Standards and Technology [NIST], 2025). Least privilege and segmentation limit the damage. If credentials are disclosed, the company should reset the password, revoke active sessions, and review access logs.

Conclusion

This attack works by making attacker-controlled messages appear to confirm one another, particularly when employees are unfamiliar with support procedures. Each stage depends on the employee trusting an email or caller without checking it independently. As attacks become more polished, the company cannot rely on employees noticing mistakes. Its best defenses are an established verification process, phishing-resistant authentication that makes a stolen password insufficient, and rapid reporting and containment when an attack still succeeds.

References

Cybersecurity and Infrastructure Security Agency. (n.d.). *Require multifactor authentication*. https://www.cisa.gov/audiences/small-and-medium-businesses/secure-your-business/require-multifactor-authentication

Cybersecurity and Infrastructure Security Agency. (2024, June 12). *Phone scammers impersonating CISA employees*. https://www.cisa.gov/news-events/alerts/2024/06/12/phone-scammers-impersonating-cisa-employees

Cybersecurity and Infrastructure Security Agency. (2025). *Scattered Spider* (Cybersecurity Advisory AA23-320A). https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a

Federal Communications Commission. (n.d.). *Caller ID spoofing*. https://www.fcc.gov/spoofing

National Cyber Security Centre. (n.d.). *Phishing attacks: Defending your organisation*. https://www.ncsc.gov.uk/pdfs/guidance/phishing.pdf

National Institute of Standards and Technology. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST Special Publication 800-63B-4). https://doi.org/10.6028/NIST.SP.800-63B-4

TryHackMe. (n.d.-a). *Common attacks*. https://tryhackme.com/r/room/commonattacks

TryHackMe. (n.d.-b). *Phishing*. https://tryhackme.com/r/room/phishingyl

TryHackMe. (n.d.-c). *Phishing analysis fundamentals*. https://tryhackme.com/r/room/phishingemails1tryoe

TryHackMe. (n.d.-d). *Phishing analysis tools*. https://tryhackme.com/r/room/phishingemails3tryoe

TryHackMe. (n.d.-e). *Phishing emails in action*. https://tryhackme.com/r/room/phishingemails2rytmuv

TryHackMe. (n.d.-f). *Phishing prevention*. https://tryhackme.com/r/room/phishingemails4gkxh

Westholt, C., & Straub, T. (2025). *Old hands won't click so easily: Findings of a large-scale phishing simulation.* (pp. 678–683). Association for Computing Machinery. https://doi.org/10.1145/3743049.3748582

Appendix

Disclosure of Artificial Intelligence Use

I used Claude, a generative artificial intelligence (AI) tool, while preparing this paper (Anthropic, 2026). The tool reviewed my drafts against the assignment and rubric, suggested revisions and replacement wording, helped locate sources, and applied APA formatting. I wrote the original draft, directed the revisions, contributed my own analysis and edits throughout, and verified the final content and sources.